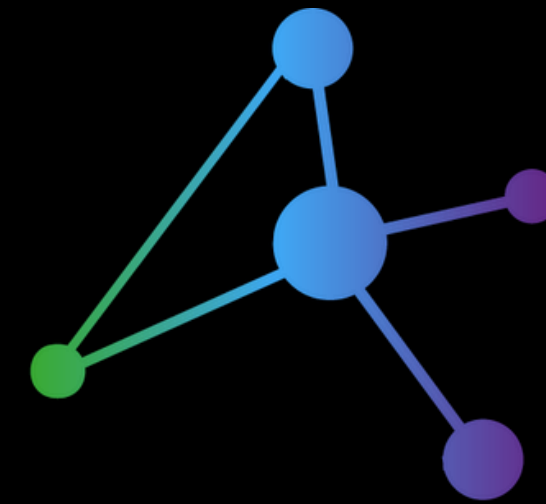




mindthesecc
2 0 2 6

**Aviso legal / Disclaimer / Descargo de
responsabilidade**

As apresentações destinam-se apenas a fins educacionais e não substituem o julgamento profissional independente. As declarações de fato e opiniões aqui expressas são de total responsabilidade dos participantes e não representam a opinião ou posição do Mind The Sec ou de quaisquer outros co-patrocinadores. O Mind The Sec não endossa, aprova ou assume responsabilidade pelo conteúdo, precisão ou integridade das informações aqui apresentadas. Os participantes devem observar que as sessões podem ser gravadas em áudio ou vídeo e podem ser publicadas em diversos meios, incluindo formatos impressos, de áudio e vídeo, sem aviso prévio adicional. O modelo de apresentação e qualquer captura de mídia estão sujeitos à proteção por direitos autorais.

The presentations are intended for educational purposes only and are not a substitute for independent professional judgment. The statements of fact and opinions expressed herein are solely the responsibility of the participants and do not represent the opinion or position of Mind The Sec or any other co-sponsors. Mind The Sec does not endorse, approve or assume responsibility for the content, accuracy or integrity of the information presented here.

Participants should note that sessions may be audio or video recorded and may be published in a variety of media, including print, audio and video formats, without further notice. The presentation template and any media capture are subject to copyright protection. Las presentaciones están destinadas únicamente a fines educativos y no sustituyen el juicio profesional independiente. Las declaraciones de hecho y las opiniones aquí expresadas son las de los participantes y no representan la opinión o posición de Mind The Sec ni de ningún otro copatrocinador. Mind The Sec no respalda, aprueba ni asume responsabilidad por el contenido, exactitud o integridad de la información aquí presentada.

Da Recepção ao Acesso Total: Pentest Físico na Vida Real

“Como entrar sem arrombar nada”

Lucas Farias

Red Team Tech
Lead na Pluxee



Quem sou eu

- Lucas Farias - 25 anos
- Formado em Análise e Desenvolvimento de Sistemas pela FSA
- Pós-graduado em Ethical Hacking e CyberSecurity pela Unicv
- 7 anos de experiência em SI
- Red Team Tech Lead
- Líder Técnico em dezenas de Pentests em empresas nacionais e internacionais
- Bug Hunter
- Autor da CVE-2023-31893
- Possui as certificações PNPT, CEH Practical, eJPT, CNPen e CAP
- Palestrante:
 - ✓ MindTheSec2023 (Operação Red Team, do zero ao Domain Admin)
 - ✓ H2HC 2024 (Chain Exploits: Como Combinar Múltiplas Vulnerabilidades para Aumentar o Impacto)
 - ✓ Hacking na Web Day 2025 (Emulando Adversários: Mostrando os Principais Ataques que Impactaram Empresas Brasileiras em 2024 e 2025)

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthese**sec**
2 0 2 6

O que é Pentest?

É uma avaliação de segurança que simula ataques reais para identificar vulnerabilidades, falhas de configuração e fraquezas em pessoas, processos e tecnologias, permitindo medir o impacto e fortalecer a segurança da organização.

E Pentest Físico?

Pentest físico é uma simulação de ataque que avalia a capacidade de um atacante de obter acesso físico não autorizado a instalações, áreas restritas, equipamentos e informações, explorando falhas em controles de acesso, processos, tecnologia e engenharia social.

O que tentamos responder em um pentest físico?

- É possível entrar na organização sem autorização?
- Os controles de acesso realmente funcionam?
- O reconhecimento facial pode ser contornado?
- A recepção consegue identificar uma tentativa de engenharia social?
- Um visitante consegue acessar áreas restritas?
- O atacante consegue chegar a computadores?
- Existem informações expostas?
- Um acesso físico permite obter credenciais?

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS



Escopo – Banco Fictício

- 📍 Local: Av. Fictícia, 123 - Vila Nova - São Paulo.
- 🏢 Andares permitidos: 01º, 02º e 03º (Diretoria).
- 🏢 Tipo de ambiente: Prédio comercial compartilhado com outras empresas.

Escopo – Inventado Finanças

- 🏢 Nome da empresa: Inventado Finanças

Objetivo

O objetivo do pentest foi avaliar a efetividade dos controles de segurança física do Banco Fictício e Inventado Finanças, identificando vulnerabilidades que permitam acesso não autorizado a ambientes corporativos, sistemas, redes, aplicações e informações sensíveis.

**Da Recepção ao Acesso Total: Pentest Físico na
Vida Real** – LUCAS FARIAS

mindthesec
2 0 2 6

**MIND
THE SEC**
— 2026 —

RECONHECIMENTO EXTERNO



Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Reconhecimento Externo

➤ Empresa

- ✓ Endereços
- ✓ Filiais
- ✓ Horários de funcionamento
- ✓ Estrutura dos escritórios
- ✓ Fotos internas
- ✓ Fotos de funcionários
- ✓ Eventos
- ✓ Plantas/locais publicados
- ✓ Empresas terceirizadas
- ✓ Prestadores de serviço

➤ Pessoas

- ✓ Funcionários
- ✓ Cargos
- ✓ Gerentes
- ✓ TI
- ✓ Facilities
- ✓ Segurança
- ✓ RH
- ✓ Recepção
- ✓ Terceirizados

➤ Infraestrutura Física

- ✓ Entradas
- ✓ Estacionamentos
- ✓ Elevadores
- ✓ Catracas
- ✓ Portarias
- ✓ Câmeras visíveis
- ✓ Leitores
- ✓ Controle de visitantes

➤ Ambiente do Cliente

- ✓ Domínios e Subdomínios
- ✓ IP's
- ✓ Arquivos Expostos
- ✓ Credenciais Vazadas
- ✓ E-mail válidos
- ✓ Portas e serviços expostos
- ✓ Informações públicas sobre o ambiente

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS



Informações do Ambiente

Descrição

Identificar informações públicas sobre a estrutura interna do prédio e ambiente corporativo para facilitar o planejamento do acesso.

Atividades Realizadas

- Coleta de imagens internas divulgadas em redes sociais (LinkedIn).
- Identificação de layout de baias e ambientes corporativos.
- Levantamento de informações públicas sobre o prédio (anúncios comerciais).

Resultado

- Visualização prévia da estrutura interna do ambiente.
- Entendimento do layout de andares e áreas de trabalho.
- Apoio ao planejamento de movimentação e abordagem no local.

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Informações do Ambiente

Recon Externo

Banco Fictício



Lopes Desde 1935 Apartamentos na Planta Prontos ▾ Aluguel ▾ Links Úteis ▾ Simulador Minha Casa Minha Vida **NOVO**

Condomínio Edifício Nova Fictícia

Av. Fictícia, 123 - Vila Nova - São Paulo

Área	Dormitórios	Banheiros	Vagas	Ano de construção	IPTU	Condomínio	Faixa de preço
800 - 805m ²	-	20	5 - 155	-	R\$ 6.575 - R\$ 8.200	R\$ 15.378 - R\$ 17.463	-

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS



Reconhecimento Externo

Recon Externo

Inventado Finanças

1. Mapeamento da superfície externa:

- `subfinder -d inventadofinancas.com.br | httpx > results-subfinder.txt`
- `amass enum -brute -d inventadofinancas.com.br -w subdomains-top1million-20000.txt | httpx > results-amass.txt`

2. Durante a análise dos subdomínios, identificamos uma aplicação responsável pelo Single Sign-On (SSO) da organização. Após a autenticação, o usuário poderia acessar diferentes serviços corporativos sem a necessidade de fornecer novamente suas credenciais, em um modelo semelhante ao utilizado por soluções como o Okta. Foi identificado também que a autenticação utilizava as mesmas credenciais do Active Directory (AD).

3. Enumeração de possíveis contas corporativas:

- Hunter.io
 - LinkedIn
 - LinkedInDumper
- ✓ `python3 linkedindumper.py --url 'https://www.linkedin.com/company/inventadofinancas' --cookie '<cookie>' --email-format '{0}.{1}@inventadofinancas.com.br'`

**Da Recepção ao Acesso Total: Pentest Físico na
Vida Real** – LUCAS FARIAS

mindthesec
2 0 2 6

**MIND
THE SEC**
— 2026 —

RECONHECIMENTO ON-SITE

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Informações do Ambiente Físico

Recon On-site

Nas 2 empresas

Descrição

Mapear controles físicos e identificar possíveis pontos de acesso ao ambiente antes da exploração.

Atividades Realizadas

- Visita presencial ao local (pré-teste).
- Identificação de métodos de autenticação na entrada.
- Mapeamento de acessos (entradas, saídas e estacionamento).
- Interação com equipe de segurança para coleta de informações.
- Observação do fluxo de pessoas e funcionamento do ambiente.

Resultado

- Identificação dos principais controles de acesso físico.
- Entendimento do funcionamento da recepção e segurança.
- Mapeamento de rotas e possíveis vetores de entrada.
- Planejamento mais assertivo da fase de exploração.

**Da Recepção ao Acesso Total: Pentest Físico na
Vida Real** – LUCAS FARIAS

mindthesec
2 0 2 6

**MIND
THE SEC**
— 2026 —

RESUMO DO RECONHECIMENTO

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Resumo Recon

Banco Fictício

 Mapeamento do ambiente: estimativa da estrutura interna dos andares a partir de fotos no LinkedIn e anúncios de imóveis.

 Métodos de entrada identificados:

 Reconhecimento facial — método predominante.

 RFID via crachá — utilizado por poucos colaboradores.

 Acesso pelo estacionamento — carro, moto e bicicleta, com controles semelhantes à entrada principal.

 Recepção: 2 a 3 atendentes, com fluxo constante de pessoas solicitando informações.

 Segurança: diversos agentes distribuídos pelo prédio, devido à existência de múltiplas entradas.

 Posto principal: 1 segurança fixo na recepção, demonstrando alto nível de atenção e aparente função de liderança.

 Identificação visual: levantamento do padrão de vestimenta utilizado pelos colaboradores.

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Resumo Recon

💰 Inventado Finanças

📋 Métodos de entrada identificados:

💳 RFID via crachá.

📱 QR Code gerado em totem de autoatendimento.

💻 Totem de acesso: solicita CPF, data de nascimento e captura de fotografia para geração do QR Code.

📖 Mapeamento interno: identificação dos andares ocupados pela empresa através do painel da recepção.

🔔 Recepção: 3 atendentes realizando o atendimento aos visitantes.

🛡️ Segurança: 2 a 3 agentes realizando rondas e prestando suporte próximo ao totem.

🚗 Estacionamento: identificação de estacionamento interno.

📄 Exposição física: identificação de um QR Code descartado no chão, próximo ao prédio.

🌐 Infraestrutura digital: identificação de uma página web com autenticação via Active Directory (AD), semelhante a um SSO corporativo, que permite acesso a outras aplicações.

**Da Recepção ao Acesso Total: Pentest Físico na
Vida Real** – LUCAS FARIAS

mindthesec
2 0 2 6

**MIND
THE SEC**
— 2026 —

PLANEJANDO ATAQUES



Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthese**sec**
2 0 2 6

Password Spraying

Planejando Ataques

Inventado Finanças

Durante a análise da aplicação de SSO, identificamos que o mecanismo de autenticação não possuía CAPTCHA ou outro mecanismo equivalente de proteção contra tentativas automatizadas.

Com isso, realizamos um password spraying controlado, utilizando a lista de usuários previamente identificada, com as seguintes senhas “Inventadofinancas@2026”, “InventadoFinancas@2026” e “Inventadofinancas!2026”.

Resultado:

- 🔍 4 credenciais válidas identificadas.
- 🔒 A autenticação exigia MFA via aplicativo.
- 📌 As credenciais foram preservadas para utilização nas etapas posteriores do teste.

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Personificação de Colaborador

Planejando Ataques

Banco Fictício

📌 Descrição

Identificar informações públicas que possibilitassem a personificação de um colaborador para acesso ao ambiente.

🔍 Atividades Realizadas

- Coleta de dados em fontes públicas (LinkedIn e ferramentas OSINT).
- Identificação de colaborador com informações suficientes para exploração.
- Levantamento de dados pessoais e corporativos (nome completo e e-mail).

⚠️ Resultado

- Identificação de colaborador com informações expostas.
- Validação de e-mail corporativo.
- Criação de identidade falsa (documento) para tentativa de acesso.
- Possibilidade de utilização em abordagem à recepção (engenharia social).

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Personificação de Colaborador

Planejando Ataques

Banco Fictício

🔍 Critérios que defini para encontrar o melhor alvo

- Ter o mesmo nome que o meu – Não ter risco de eu falar errado (Lucas).
- Ter o nome completo no LinkedIn – Ficar mais fácil de achar os dados.
- Morar no estado e/ou região próxima do escritório da empresa alvo.
- Trabalhar de forma presencial ou híbrida – Tem mais chance de já ter realizado o cadastro na recepção do prédio.
- Estar pelo menos um ano na empresa – Tem mais chance de já ter ido pelo menos uma vez no escritório.
- Ter encontrado o possível e-mail corporativo dele no Hunter.io.
- Encontrar o possível gestor dele no LinkedIn.

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

Personificação de Colaborador

Planejando Ataques

Banco Fictício

mindthesec
2026

The image shows a screenshot of a LinkedIn profile for 'Lucas Conta Fake'. The profile is for a 'Gerente de Produtos de Crédito | Especialista em Jornadas Digitais e Inovação Financeira' at 'BANCO FICTÍCIO'. The profile includes a profile picture, a cover image with the bank's logo, and a list of work experiences. The work experiences are: 'Gerente de Produtos de Crédito Híbrido' (3 years 4 months), 'Gerente de Produtos Sênior' (3 years 4 months), and 'Gerente de Produtos Júnior' (1 month). The profile also shows 'Mais de 100 conexões' and buttons for 'Enviar mensagem', '+ Seguir', and 'Mais'.

linkedin.com/in/lucas-conta-fake-987a65432/

Lucas Conta Fake ✓
Gerente de Produtos de Crédito | Especialista em Jornadas Digitais e Inovação Financeira
São Paulo, São Paulo, Brasil · Mais de 100 conexões

BANCO FICTÍCIO
— CONFIANÇA QUE MOVE O FUTURO. —

Experiência

- Gerente de Produtos de Crédito Híbrido**
Tempo total: 3 anos 4 meses
- Gerente de Produtos Sênior**
São Paulo, Brasil
jun de 2021 - o momento · 3 anos 4 meses
Responsável por liderar a squad de aquisição digital de crédito consignado. Focado em melhorias de jornada e eficiência, alcançando +25% de conversão de funil. Gestão end-to-end de produto, de discovery à implementação de novos canais de venda.
- Gerente de Produtos Júnior**
São Paulo, Brasil
jun de 2021 - jun de 2021 · 1 mês
Product Strategies, Gestão de Squads e mais 5 competências

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2026

Personificação de Colaborador

Planejando Ataques

Banco Fictício

Consulta NOME

yanbuscas.com/consultar?tipo=NOME

Yan Buscas

Dashboard / Consulta NOME

198/200 consultas

Buscas

Indicações

Assinatura

Revenda

Ajuda & Suporte

Sair

Consulta NOME

Preencha os dados necessários para realizar a consulta

Consulta disponível no seu plano

Digite o NOME completo

Lucas Conta Fake

Consultar

Resultado da Consulta

Copiar

NOME: Lucas Conta Fake

CPF: 123.456.789-01

NASCIMENTO: 15/18/1990

Consulta CPF

yanbuscas.com/consultar?tipo=CPF

Yan Buscas

Dashboard / Consulta CPF

198/199 consultas

Dashboard

Indicações

Assinatura

Revenda

Apis

Configurações

Meu Perfil

Ajuda & Suporte

Sair

Consulta CPF

Preencha os dados necessários para realizar a consulta

Consulta disponível no seu plano

Digite o número do CPF

123.456.789-01

Consultar

Resultado da Consulta

Copiar

CPF: 123.456.789-01

NOME: Lucas Conta Fake

SEXO: M

NASCIMENTO: 15/18/1990

NOME NAE: Narlana da Silva Fake

NOME PAI: Pedre da Silva Fake

ESTADO CIVIL: SOLTEIRO

RG: 98.765.432-1

CBO: Analista Senior

ORGÃO EMISSOR: SSP/SP

UF EMISSÃO: SP

DATA C0270: 3EM RESULTADO

RENDA: \$500.75

TITULO ELEITOR: 812345678901

CSBB: 358

CSBB FAZXA: MEDIO

CSBA: 728

CSBA FAIXAL: ALTO

EMAIL: lucas.fake@emailpro.com

FONE FIXO: 113456-7890

FONE CELULAR: 1198769-4321

FONE CELULAR: 1199999-9899

ENDEREÇO: Rua das Contas, 123, CEP 01001-000

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2026

Planejando Ataques

Banco Fictício

Personificação de Colaborador



Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS



Personificação de Colaborador

Planejando Ataques

Banco Fictício

Email Verifier ?

Upload a list of email addresses to verify

 lucas.contafake@bancoficticio.com.br

 Banco Fictício

Verify | 0.5



lucas.contafake@bancoficticio.com.br is valid

This email address can be used safely.

 100% [See details](#)

Add to a list

Add to a sequence

We used data from **1 source** on the web.

[See sources](#) 



Stay informed about changes at Banco Fictício.

Get notified when Banco Fictício opens new jobs, raises funds, and more.

Follow this company



We found 389 email addresses for bancoficticio.com.br.

Find the list of email addresses associated with this company that are publicly available on the web.

See all results

Possível gestor do Lucas:

- Nome: Gerente Fake
- LinkedIn:
<https://www.linkedin.com/in/gerente-fake>
- E-mail: gerente.fake@bancoficticio.com.br

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2026

Planejando Ataques

Banco Fictício

Criando um crachá falso



Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Planejando Ataques

Banco Fictício

Criando um crachá falso



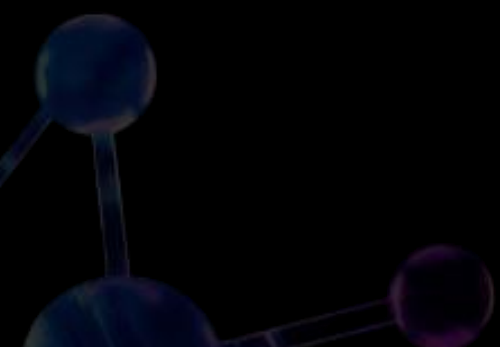
Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS



mindthesec
2026

**MIND
THE SEC**
— 2026 —

ENTRANDO NO PRÉDIO



Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Entrando no prédio

Banco Fictício

Preparação inicial

- 🎭 Personificação: definição da identidade e do perfil de um colaborador.
- 🪪 Crachá falso: criação de um crachá compatível com o perfil personificado.
- 🧠 Planejamento do cenário de acesso:
 1. 🏢 Chegar ao prédio utilizando o crachá do Banco.
 2. 👤 Tentar o reconhecimento facial e aguardar a negativa.
 3. 🔔 Acionar a recepção alegando falha no reconhecimento facial.
 4. 🪪 Informar os dados do colaborador personificado e apresentar a CNH falsa, se necessário.
 5. 📞 Aguardar a validação das informações junto ao Banco.
 6. 🗝️ Prosseguir conforme o procedimento adotado: novo cadastro facial ou liberação de acesso.
- 🚶 Tailgating: utilização do acesso de outro colaborador para ultrapassar o controle de acesso ao andar do Banco.

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Entrando no prédio

Inventado Finanças

Preparação inicial

👤 Obtenção de dados: levantamento de nome completo, CPF e data de nascimento de um colaborador para utilização no totem.

📱 QR Code: manutenção do QR Code encontrado no chão para validar se seria possível utilizá-lo para acesso.

🧠 Planejamento do cenário de acesso:

1. 🏢 Chegar ao prédio.
2. 📱 Tentar utilizar o QR Code encontrado no chão para entrar.
3. ❌ Caso falhasse, utilizar o totem para tentar gerar um novo QR Code.
4. ❌ Caso ainda falhasse, acionar a recepção e informar os dados do colaborador obtidos previamente.

🚶 Tailgating: utilização do acesso de outro colaborador para ultrapassar o controle de acesso ao andar da empresa.

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Entrando no prédio

Banco Fictício

Execução real

- 🏢 Chegada: acesso ao prédio e deslocamento até a primeira catraca.
- 👤 Reconhecimento facial: tentativa de autenticação com meu rosto → acesso negado.
- 🔔 Interação com a recepção: informei a falha; a recepcionista realizou uma ação no tablet e solicitou uma nova tentativa.
- 🔓 Acesso concedido: nova tentativa de reconhecimento facial → catraca liberada vinculada ao nome de outra pessoa.
- 📖 Reconhecimento interno: após a primeira catraca, identifiquei o andar da empresa e, ao chegar, observei o ambiente e o comportamento dos colaboradores.
- 📦 Controle das baias: identifiquei um segundo controle de acesso baseado em reconhecimento facial.
- 👤 Nova tentativa: reconhecimento com meu rosto → acesso negado.
- 🚶 Tailgating: aguardei a passagem de um colaborador e aproveitei o acesso para ultrapassar o segundo controle.

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesesec
2026

Entrando no prédio

Banco Fictício

Execução real



Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Entrando no prédio

Inventado Finanças

Execução Real

- 🏢 Chegada: acesso ao prédio e deslocamento até a primeira catraca.
- 📱 QR Code: utilização do QR Code encontrado no chão → acesso liberado.
- 🚶 Deslocamento: identificação do andar da empresa e acesso ao respectivo local.
- 🔒 Controle interno: ao chegar ao andar, foi identificado que não havia acesso às áreas corporativas sem passar pelo reconhecimento facial, sendo permitido apenas o acesso aos elevadores.
- 📞 Pretexto: simulação de uma ligação telefônica enquanto aguardava a chegada de um colaborador.
- 🕒 Oportunidade: em menos de 2 minutos, um colaborador chegou e abriu o acesso.
- 🚶 Tailgating: aproveitamento da abertura da porta para entrar de carona, ultrapassando o controle de acesso.

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS



mindthesecc
2 0 2 6

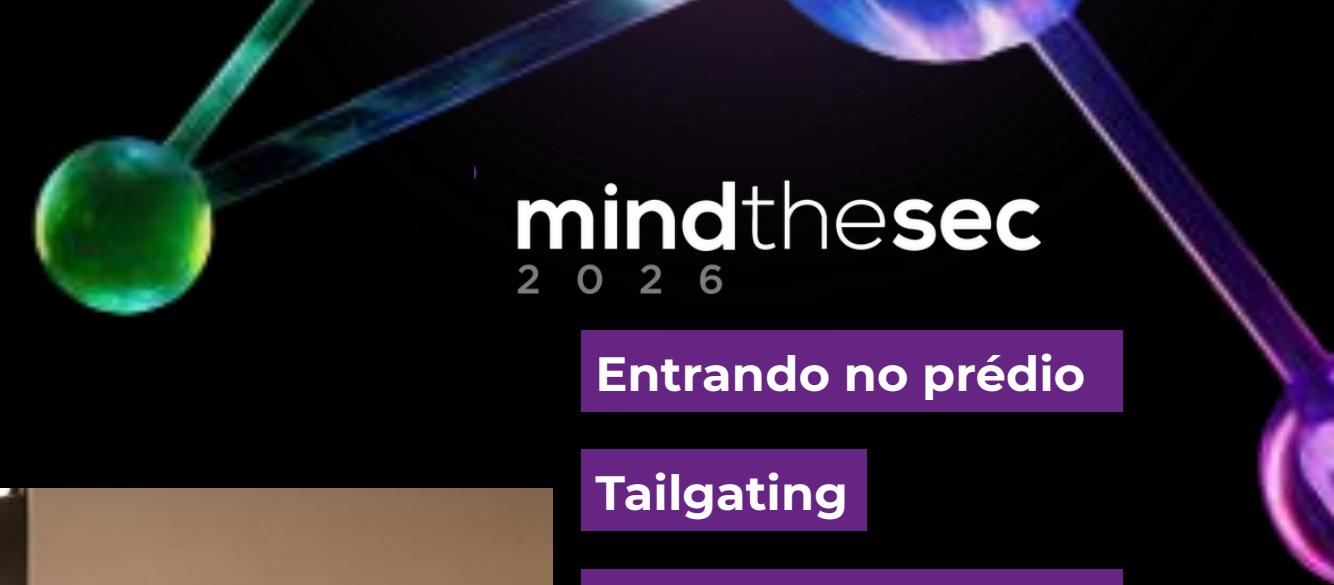
Entrando no prédio

Inventado Finanças

Execução real



Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS



Entrando no prédio

Tailgating

Ambas as empresas

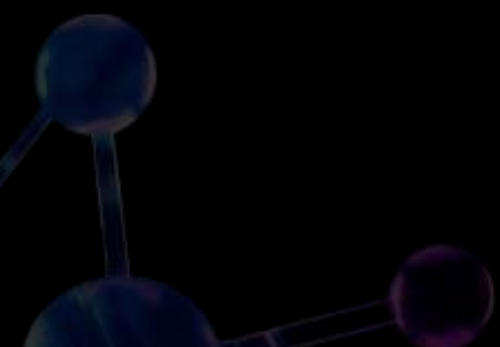
**Da Recepção ao Acesso Total: Pentest Físico na
Vida Real** – LUCAS FARIAS



mindthesec
2 0 2 6

**MIND
THE SEC**
— 2026 —

RECONHECIMENTO INTERNO



Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Recon Interno

Ambas as empresas

O que fazer logo após entrar?

🚶 Reconhecimento inicial: realizar uma volta rápida pelo ambiente para entender a dinâmica do andar e identificar se as mesas são reservadas ou de livre utilização. Após a análise, escolher uma mesa.

📖 Reconhecimento detalhado: circular pelo andar de forma natural e discreta, observando:

1. 📄 Salas de reunião e respectivos controles de acesso.
2. 🚫 Salas privativas e áreas restritas.
3. ☕ Copa e áreas de convivência.
4. 🖨 Impressoras e equipamentos disponíveis.
5. 💻 Tecnologias e dispositivos utilizados internamente.
6. 🏢 Estrutura e organização geral do ambiente.

🗑 Comportamento: utilizar uma atividade cotidiana, como pegar uma garrafa de água, para realizar o reconhecimento de forma natural e sem levantar suspeitas.

💻 Estação de trabalho: após selecionar a mesa, verificar a infraestrutura disponível:

1. 🔌 Possibilidade de conexão via RJ45.
2. 📶 Disponibilidade de Wi-Fi corporativo ou visitante.
3. 🌐 Possibilidade de acesso à internet e recursos de rede.

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesecc
2 0 2 6

Recon Interno

Inventado Financas

Acesso a rede corporativa

Login na rede Wireless Corporativa utilizando uma das credenciais que identificamos via Password Spraying

← Wi-Fi

Galaxy AS3 5G81C7

Inventado Financas Seguro

Insira seu nome de usuário e senha

colaborador.fake

Inventadofinancas@2026

Conectar usando certificado

OK Cancelar

Configurações command Prompt

```
Microsoft Windows [Versão 10.0.19045.3999]
(c) Microsoft Corporation. Todos os direitos reservados.

C:\Users\colaborador.fake>ipconfig

Adaptador de Rede sem Fio Wi-Fi:

    Sufixo DNS específico de conexão.: inventadofinancas.com
    Endereço IPv6 de link local . . . : fe80::a1b2:c3d4:e5f6:7g8h%12
    Endereço IPv4. . . . . : 10.152.181.102
    Máscara de Sub-rede . . . . . : 255.255.0.0
    Gateway Padrão. . . . . : 10.152.1.1

C:\Users\colaborador.fake>
```

← Configurações de Rede

Wi-Fi

Inventado Financas Seguro Conectado

**Da Recepção ao Acesso Total: Pentest Físico na
Vida Real** – LUCAS FARIAS

mindthese**sec**
2 0 2 6

**MIND
THE SEC**
— 2026 —

ATAQUES

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesecc
2 0 2 6

Comprometimento de Credenciais via Quishing

Ataque Físico

Banco Fictício

É ANO DE
COPA

**E JUNTOS VAMOS
TRAZER O HEXA!**

AFINAL, O PROFESSOR JA DISSE: TA
LIBERADO ACREDITAR!

ESCANEIE O ORCODE E **RESGATE SUA
CAMISETA DO BRASIL**, VEM TORCER
COM O **BANCO FICTÍCIO!**

AH, VALE LEMBRAR QUE O ACESSO DEVE SER FEITO
COM SEU LOGIN CORPORATIVO PARA SER VALIDADO.



 **banco
fictício**

VÁLIDO APENAS PARA COLABORADORES DO BANCO FICTÍCIO

Dimensions: iPhone 14 Pro Max ▾ 430 × 932 100% ▾ No throttling ▾ 'Save-Data': default ▾

 **banco fictício**

Entrar

Email

Senha

[Não tem uma conta? Crie uma!](#)

[Não consegue acessar sua conta?](#)

[Opções de entrada](#)

Avançar

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Comprometimento de Credenciais via Quishing

Ataque Físico

Banco Fictício

← → ↺ <https://servicos.bancoficticio.com.br/Forms/Pages/Colaborador/ResponsePage.aspx> A ☆ ⚙️ ☆ 📄 👤 ...

BEM-VINDO COLABORADOR BANCO FICTÍCIO! TA LIBERADO ACREDITAR!

Preencha as informações para validar seu cadastro e resgatar sua camiseta do Brasa!

Quando você enviar este formulário, ele não coletará automaticamente seus detalhes, como nome e endereço de email, a menos que você mesmo o forneça.

* Obrigatória

- Nome Completo *
- Informe seu E-mail corporativo *
- Informe seu CPF *
- Há quanto tempo é colaborador do Banco Fictício? *
- Escolha o tamanho da sua camiseta *

☐ P
☐ M
☐ G

BC Banco Fictício

© 2026 Banco Fictício S.A. | Atendimento: 0800-FAKE-BANK

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesecc
2 0 2 6

Comprometimento de Credenciais via Quishing

Ataque Físico

Banco Fictício



Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Comprometimento de Credenciais via Quishing

Ataque Físico

Banco Fictício

[16-09-2026 12:59:58] IP: 127.0.0.1 | EMAIL: colaborador.fake1@bancoficticio.com.br | PASSWORD: Senha@fake1 | UA: Mozilla/5.0 (Linux; Android 10; K) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Mobile Safari/537.36

[16-09-2026 13:35:02] IP: 127.0.0.1 | EMAIL: colaborador.fake2@bancoficticio.com.br | PASSWORD: Senha@fake2 | UA: Mozilla/5.0 (Linux; Android 10; K) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Mobile Safari/537.36

[16-09-2026 13:51:32] IP: 127.0.0.1 | EMAIL: colaborador.fake3@bancoficticio.com.br | PASSWORD: Senha@fake3 | UA: Mozilla/5.0 (iPhone; CPU iPhone OS 18_7 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/26.1 Mobile/15E148 Safari/604.1

[16-09-2026 14:16:18] IP: 127.0.0.1 | EMAIL: colaborador.fake4@bancoficticio.com.br | PASSWORD: Senha@fake4 | UA: Mozilla/5.0 (iPhone; CPU iPhone OS 26_3_1 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) CriOS/146.0.7680.151 Mobile/15E148 Safari/604.1

[16-09-2026 14:16:19] IP: 127.0.0.1 | EMAIL: colaborador.fake5@bancoficticio.com.br | PASSWORD: Senha@fake5 | UA: Mozilla/5.0 (iPhone; CPU iPhone OS 26_3_1 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) CriOS/146.0.7680.151 Mobile/15E148 Safari/604.1

[16-09-2026 14:28:40] IP: 127.0.0.1 | EMAIL: colaborador.fake6@bancoficticio.com.br | PASSWORD: Senha@fake6 | UA: Mozilla/5.0 (iPhone; CPU iPhone OS 18_7 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/26.3 Mobile/15E148 Safari/604.1

[16-09-2026 14:50:24] IP: 127.0.0.1 | EMAIL: colaborador.fake7@bancoficticio.com.br | PASSWORD: Senha@fake7 | UA: Mozilla/5.0 (iPhone; CPU iPhone OS 18_5 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/18.5 Mobile/15E148 Safari/604.1

[16-09-2026 14:53:03] IP: 127.0.0.1 | EMAIL: colaborador.fake8@bancoficticio.com.br | PASSWORD: Senha@fake8 | UA: Mozilla/5.0 (Linux; Android 10; K) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Mobile Safari/537.36

[16-09-2026 14:57:40] IP: 127.0.0.1 | EMAIL: colaborador.fake9@bancoficticio.com.br | PASSWORD: Senha@fake9 | UA: Mozilla/5.0 (Linux; Android 10; K) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Mobile Safari/537.36

[16-09-2026 15:01:27] IP: 127.0.0.1 | EMAIL: colaborador.fake10@bancoficticio.com.br | PASSWORD: Senha@fake10 | UA: Mozilla/5.0 (iPhone; CPU iPhone OS 18_7 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/26.3 Mobile/15E148 Safari/604.1

Safari/604.1

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Possibilidade de Engenharia Social no CEO

📌 Achado

Dispositivo encontrado em sala de reunião aberta, expondo informações internas sem autenticação.

⚠️ Resultado

- Enumeração de usuários administrativos.
- Possibilidade de realizar chamadas internas.
- Exposição de informações sensíveis.

💥 Impacto

- Facilitação de vishing direcionado, fraude e potencial comprometimento de contas privilegiadas.



Ataque Físico

Banco Fictício

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Estação de Trabalho Desbloqueada

Ataque Físico

Banco Fictício



📌 Achado

Dispositivo encontrado desbloqueado durante o horário de almoço.

🌟 Ações executadas

- Exfiltração de dados e documentos internos via e-mail.
- Dumping completo dos usuários do AD e envio para o meu e-mail.
- Tentativa de acesso a senhas salvas no navegador.
- Tentativa de enumeração da máquina e envio dos documentos para o meu C2 (bloqueado pelo EDR).
- Tentativa de execução de comandos via BAD USB com o Flipper Zero (bloqueado pelo EDR).

⚠️ Objeção encontrada

- O colaborador me viu mexendo no computador dele. O que eu fiz?

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS



Tailgating nos controles internos

Ataque Físico

Banco Fictício



📌 Achado

Falta de controle e monitoramento para tailgating.

🌟 Ações executadas

- Consegui abusar do tailgating mais de 15 vezes em 4 horas, para se locomover dentro da organização.
- Consegui entrar em salas de reuniões/apresentações.

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Participação de apresentações internas

Ataque Físico

Banco Fictício



✦ Acontecimento

- Enquanto estava sentado na mesa que havia escolhido, uma pessoa passou informando que haveria uma apresentação/treinamento no auditório e que todos poderiam participar. Imediatamente, comecei a me organizar para ir.

⚠ Resultado

- Não foram identificadas informações sensíveis que pudessem gerar impacto relevante para a empresa durante a apresentação.

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesecc
2 0 2 6

Captura de Credenciais via Evil Portal

Ataque Físico

Inventado Financas

🌟 Objetivo

- Obter credenciais válidas de colaboradores.

⚠️ Resultado

- Nenhum colaborador submeteu as credenciais.



Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthese**sec**
2 0 2 6

**MIND
THE SEC**
— 2026 —

PÓS-EXPLORAÇÃO

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

Enumeração Interna

🔍 Port Scan

- `nmap -sSV -p- -T2 -v --open 10.152.0.0/16`

🏢 Enumeração de hosts/serviços relacionados ao AD:

- `nxc smb 10.152.181.0/24`
- `nmap -sSV -p 53,88,389 --open 10.152.181.0/24`

Identificação do Domain Controller:

- `nltest /dsgetdc:inventado.financas.local`

🔑 Validação de Credenciais no AD

- `nxc smb 10.152.181.25 -u 'colaborador.fake' -p 'Inventadofinancas@2026'`

📄 Enumeração do Active Directory

- `ldapdomaindump -u 'inventado.financas.local\colaborador.fake' \`
`-p 'Inventadofinancas@2026' 10.152.181.25`
- `enum4linux -a -u "colaborador.fake" -p "Inventadofinancas@2026" \`
`10.152.181.25 > enum4linux_ad.txt`



Pós-Exploração

Inventado Finanças

🎯 Password Spraying Interno:

- `nxc smb 10.152.181.25 \`
`-u all_users.txt \`
`-p passwords.txt > pass_spraying.txt`

Filtragem dos resultados positivos:

- `grep "+" pass_spraying.txt`
- **Conseguimos obter mais 3 credenciais válidas. Totalizando 7 credenciais.**

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Pós-Exploração

Inventado Finanças

Acesso a contas corporativas

Acesso ao Ambiente Interno

Lembram daquele sistema “SSO” que identificamos durante o reconhecimento externo, onde encontramos 4 credenciais válidas?

Ao acessá-lo novamente já dentro da rede interna, tivemos uma surpresa:

- Não havia mais uma página de login.
- O sistema utilizava apenas HTTP Basic Authentication. Ao informar uma das credenciais válidas, o acesso era concedido **sem MFA**, permitindo selecionar o Office como aplicação.
- A partir daí, foi possível acessar os produtos da Microsoft associados à conta.

Credenciais

- Das 7 credenciais válidas identificadas com o password spraying, 2 pertenciam a gerentes.

Ações realizadas

- Acesso ao Microsoft Teams dos colaboradores;
- Visualização dos e-mails das contas comprometidas;
- Identificação de diversas senhas armazenadas em documentos, incluindo credenciais pessoais;
- Utilização dessas credenciais para acessar portais externos de outras empresas.

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Pós-Exploração

Inventado Finanças

Acesso a servidores de compartilhamento

📁 File Shares

Utilizando uma das credenciais obtidas, realizei a enumeração dos File Shares disponíveis na rede:

- `nxc smb 10.152.0.0/16 -u 'colaborador.fake' -p 'Inventadofinancas@2026' --shares`

Um dos compartilhamentos me chamou atenção:

- `smbclient -L //10.152.33.7 -U 'inventado.financas.local\colaborador.fake%Inventadofinancas@2026'`
- `smbclient \\\\10.152.33.7\shared -U 'inventado.financas.local\colaborador.fake%Inventadofinancas@2026'`

★ O que foi encontrado?

Ao acessar uma das pastas, encontrei:

- Logs completos de uma aplicação, contendo diversas informações de usuários;
- Códigos-fonte de aplicações internas;
- Credenciais de banco de dados hardcoded diretamente no código-fonte.
- Uma credencial aparentemente comum levou ao acesso a informações sensíveis e segredos de aplicações.

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthese**sec**
2 0 2 6

Pós-Exploração

Inventado Finanças

Credencial Padrão no VMware ESXi

VMware ESXi — Acesso Root

Durante o Port Scan, identifiquei um serviço VMware ESXi exposto na rede.

- Ao acessar o host: <https://10.152.5.10/>

Durante a investigação, identifiquei uma credencial padrão/fraca associada ao ambiente:

- Usuário: root
- Senha: P@ssw0rd
- Ao testar a credencial, obtive acesso administrativo (root) ao VMware ESXi.

★ **Impacto**

Com acesso ao hypervisor, foi possível:

- Acessar máquinas virtuais do ambiente;
- Interagir diretamente com uma das VMs;
- Criar uma nova máquina virtual no ambiente.
- Uma credencial fraca resultou em comprometimento do hypervisor e controle sobre o ambiente virtualizado.

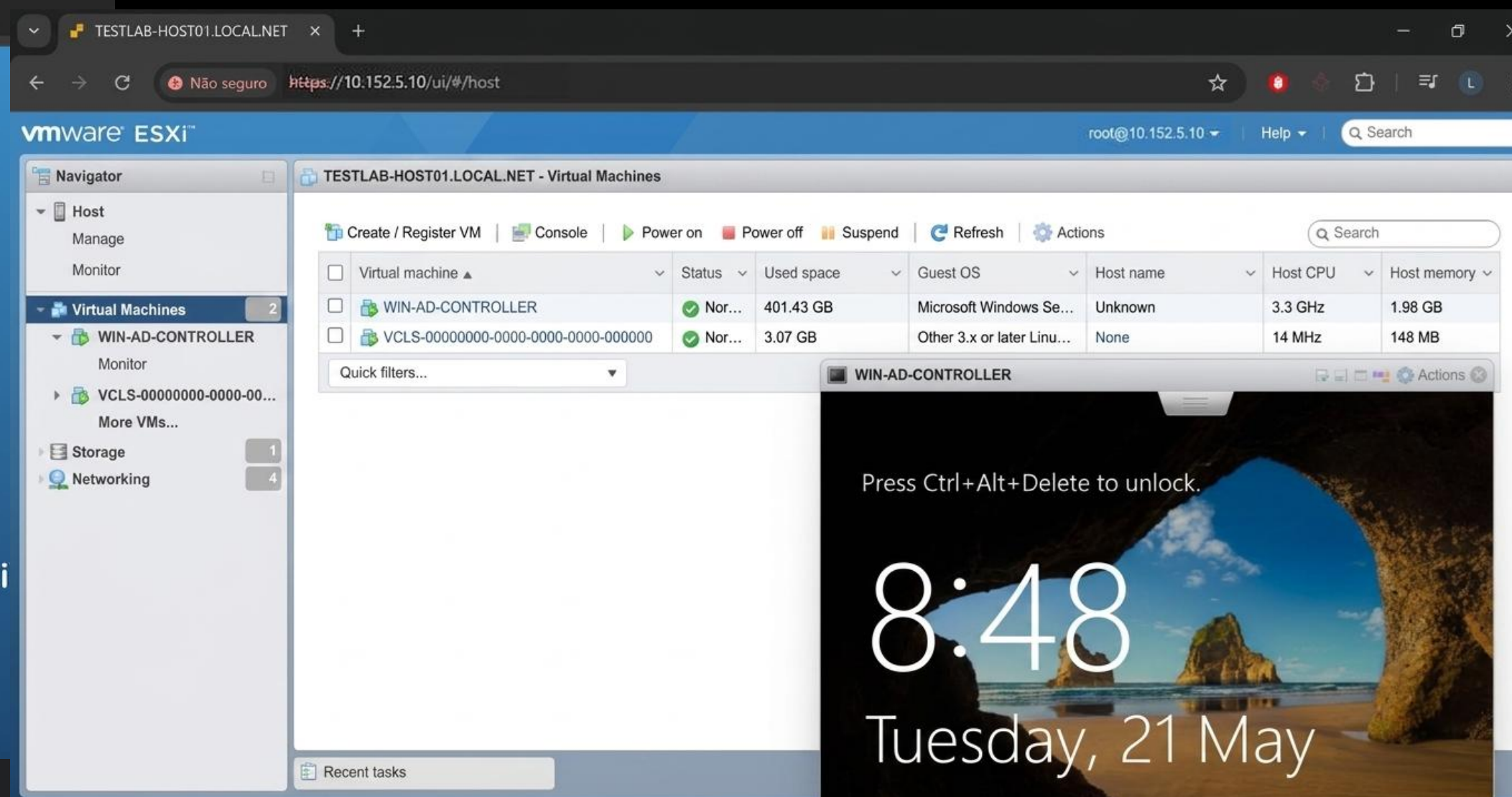
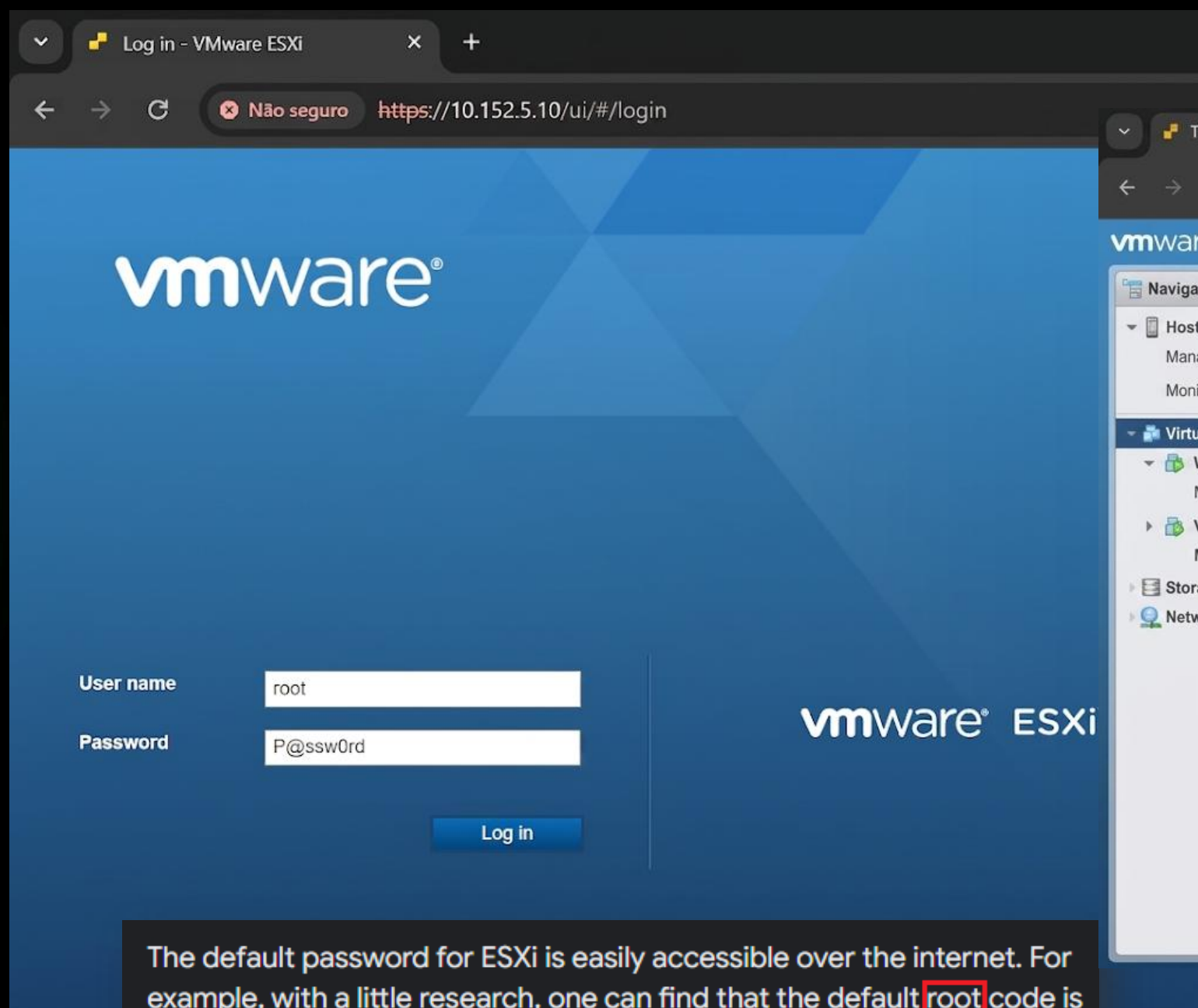
Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesecc
2026

Credencial Padrão no VMware ESXi

Pós-Exploração

Inventado Finanças



The default password for ESXi is easily accessible over the internet. For example, with a little research, one can find that the default **root** code is **"PASSWORD"** ("O" = numeric zero). For ESXi 6.7 the default root code is **"P@ssw0rd"** ("@" = at sign; "0" = numeric zero) or it is blank (that is, no password).



Passwarden

<https://www.passwarden.com> › Help › use-cases

ESXi Default Password and Benefits of Passwarden

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2026

Credencial Padrão no VMware ESXi

Pós-Exploração

Inventado Finanças

vmware ESXi™

root@10.152.5.10 | Help | Search

TESTLAB-HOST01.LOCAL.NET - Virtual Machines

Create / Register VM | Console | Power on | Power off | Suspend | Refresh | Actions

Virtual machine	Status	Used space	Guest OS	Host name	Host CPU	Host memory
☒ Pentest	✓ Nor...	1.75 KB	Ubuntu Linux (64-bit)	Unknown	0 MHz	0 MB
☐ WIN-AD-CONTROLLER	✓ Nor...	401.43 GB	Microsoft Windows Se...	Unknown	552 MHz	8.05 GB
☐ VCLS-00000000-0000-0000-0000-000000	✓ Nor...	3.07 GB	Other 3.x or later Linu...	None	5 MHz	148 MB

Quick filters... 3 items

Pentest

Guest OS: Ubuntu Linux (64-bit)
Compatibility: ESXi 6.5 and later (VM version 13)
VMware Tools: No
CPUs: 1
Memory: 1 GB

CPU: 0 MHz
MEMORY: 0 B
STORAGE: 1.75 KB

Recent tasks

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthesec
2 0 2 6

Pós-Exploração

Inventado Finanças

Credencial Padrão no FortiAP

🌐 FortiAP — Credenciais Padrão

Durante a exploração da infraestrutura, identifiquei um FortiAP acessível na rede:

- <https://10.152.5.20/>

Ao testar as credenciais padrão, foi possível autenticar no equipamento utilizando:

- Usuário: admin
- Senha: [em branco]

⚠️ Impacto

- O acesso administrativo ao equipamento foi obtido utilizando credenciais padrão, sem a necessidade de uma senha.
- Equipamentos de infraestrutura acessíveis com credenciais padrão podem representar um ponto de entrada para comprometimento da rede.

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

Credencial Padrão no FortiAP

mindthesec
2026

Pós-Exploração

Inventado Finanças

← → ↻ Não seguro https://10.152.5.20

FortiAP

admin

Password

Login

← → ↻ Não seguro https://10.55.15.26

FortiAP-221E		admin
Information		
Dashboard		
System Status		
WTP Configuration		
Radio Configuration		
Settings		
Local Configuration		
Firmware		
Hostname	Hostname Fake	
Serial Number	FP221E5521099576	
Firmware Version	FortiAP-221E v7.2.build0317.230228 (GA)	
Base MAC	e8:ed:d6:4e:6b:c8	
System		
System Time	Tue, 21 May 2024 16:35:28	
System Uptime	5 day 5 hour 42 min 9 sec	
CPU Usage	14%	
Memory Usage	71%	
Network		
IP Address	10.152.5.20/255.255.255.192	
DHCP Leasing Time	Wed, 22 May 2024 11:00:20	
Gateway	10.152.5.1	
DNS Server	10.152.44.48, 10.152.44.49, 10.152.44.50	
Radio 0		
Radio Mode	AP	
Country	BR	
Country Code	76	

**Da Recepção ao Acesso Total: Pentest Físico na
Vida Real** – LUCAS FARIAS

mindthesec
2026

**MIND
THE SEC**
— 2026 —

SAÍDA DO PRÉDIO

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

mindthese**sec**
2 0 2 6

Saída do Prédio

Saída do prédio

Ambas empresas

Banco Fictício

- Tailgating: aguardei aproximadamente 10 minutos até alguém passar para conseguir sair do andar e acessar o elevador.
- Na saída, tentei utilizar minha biometria facial, mas o acesso foi negado.
- Consegui sair utilizando tailgating novamente.
- O segurança presenciou a ação e não realizou nenhuma intervenção.

Inventado Finanças

- Tailgating: utilizei a carona de outro colaborador para sair do andar e acessar o elevador.
- Na saída do prédio, utilizei o QR Code encontrado durante o reconhecimento para obter acesso e deixar as instalações.

Da Recepção ao Acesso Total: Pentest Físico na Vida Real – LUCAS FARIAS

ENTRE EM CONTATO

Lucas Farias

[in/lucas-fp](#) | lfpiasentin@gmail.com | +55 11 94963-9255

**Obrigado pela
sua atenção**

mindthesec.com.br | [@mindthesec](#)

